

Módulo 9 – Capítulo 09 – Sección 01

EU AI Act: clasificación de sistemas de IA por riesgo y obligaciones técnicas

El EU AI Act (Reglamento UE 2024/1689, publicado en el Diario Oficial de la UE en julio de 2024) es el primer marco regulatorio integral de IA a nivel mundial y establece reglas que aplican a cualquier sistema de IA que sea desplegado o usado dentro de la Unión Europea, independientemente de donde tenga su sede el proveedor. Esta aplicación extraterritorial —similar a la del GDPR— significa que una startup en San Francisco que ofrece un servicio de IA a usuarios europeos está sujeta al AI Act igual que una empresa europea. El lector que construye sistemas de IA para clientes o usuarios en la UE no puede tratar este Reglamento como "regulación de otro país que no aplica a mi trabajo".

El AI Act estructura sus requisitos en torno a una clasificación de sistemas por nivel de riesgo que determina qué obligaciones aplican. Los sistemas de riesgo inaceptable —prohibidos desde agosto de 2024— incluyen scoring social generalizado, reconocimiento de emociones en contextos laborales y educativos, e identificación biométrica remota en tiempo real en espacios públicos. Los sistemas de alto riesgo —sujetos a las obligaciones técnicas más rigurosas— incluyen IA en infraestructura crítica, sistemas de decisión de crédito, reclutamiento automatizado, educación (sistemas que determinan el acceso a educación), aplicación de la ley, administración de justicia, y dispositivos médicos con IA. Los sistemas de riesgo limitado —chatbots y sistemas de generación de contenido— requieren principalmente transparencia: informar al usuario que está interactuando con IA. La mayoría de los sistemas de IA de propósito general usados en aplicaciones empresariales caen en la categoría de riesgo limitado por sí mismos, pero la clasificación cambia cuando se integran en aplicaciones específicas.

La implicación más importante de la clasificación por riesgo para el AI Engineer es que se aplica a la aplicación completa, no al modelo base. Un LLM de propósito general —GPT-4o accedido via API de OpenAI— es probablemente de riesgo limitado en la taxonomía del AI Act si se usa como asistente de escritura. Si ese mismo LLM se integra en una aplicación que hace recomendaciones de crédito al consumidor, la aplicación completa es de alto riesgo y debe

cumplir todos los requisitos técnicos de ese nivel, aunque el modelo base sea idéntico. Esta distinción es fundamental porque determina el presupuesto de compliance que el equipo debe asignar.

Para sistemas de alto riesgo, los requisitos técnicos que el AI Act establece directamente son: un Risk Management System (proceso documentado y continuo de identificación, análisis y mitigación de riesgos), Data Governance (documentación del dataset de entrenamiento incluyendo origen, procesamiento, características, y medidas de bias tomadas), Technical Documentation equivalente a un Model Card completo con especificaciones del modelo y resultados de evaluación de seguridad, requisitos de Accuracy, Robustness y Cybersecurity (medidos y documentados, sin especificar valores exactos), y Human Oversight (el sistema debe diseñarse para permitir supervisión humana efectiva con capacidad de intervenir o deshabilitar).

Aspectos técnicos

- **Clasificación por riesgo:** inaceptable (prohibido), alto (obligaciones técnicas completas), limitado (transparencia), mínimo (sin obligaciones específicas); la clasificación aplica a la aplicación completa, no al modelo base.
- **Requisitos técnicos para sistemas de alto riesgo:** Risk Management System documentado y continuo, Data Governance del training set, Technical Documentation equivalente a Model Card, requisitos de Accuracy/Robustness/Cybersecurity medidos, y Human Oversight efectivo con capacidad de intervenir.
- **Aplicación extraterritorial:** cualquier sistema de IA usado por o sobre ciudadanos de la UE está sujeto al AI Act, independientemente de la ubicación del proveedor; igual que el GDPR para datos personales, el AI Act aplica a donde están los usuarios, no a donde está la empresa.
- **Cybersecurity como requisito explícito:** el AI Act Art. 15 exige que los sistemas de alto riesgo sean robustos ante ataques adversariales, data poisoning, y otras amenazas de seguridad relevantes para el contexto de uso; esto hace que los controles de seguridad de este módulo sean requisitos legales, no solo buenas prácticas.
- **Multas y sanciones:** hasta 35 millones de euros o 7% del volumen de negocios mundial anual para violaciones de la prohibición de sistemas de riesgo inaceptable; hasta 15 millones o 3% para violaciones de obligaciones de sistemas de alto riesgo.

El EU AI Act clasifica el riesgo a nivel de la aplicación completa, no del modelo base: un LLM de propósito general se convierte en un sistema de alto riesgo cuando se integra en una

aplicación que toma o influye en decisiones con impacto significativo sobre personas, y en ese momento aplican todas las obligaciones técnicas de documentación, governance, robustez y supervisión humana.

Módulo 9 – Capítulo 09 – Sección 02

GDPR aplicado a sistemas de IA: base legal, minimización y derecho al olvido

El GDPR aplica a los sistemas de IA siempre que procesen datos personales de personas en la UE o EEE, lo que incluye prácticamente cualquier sistema de IA conversacional que procese inputs de texto de usuarios europeos, cualquier sistema RAG que indexe documentos con datos de clientes europeos, o cualquier pipeline de fine-tuning que use conversaciones o feedback de usuarios europeos. La pregunta "¿aplica el GDPR a mi sistema de IA?" tiene respuesta afirmativa para la mayoría de los sistemas de producción que sirven a audiencias europeas o globales. Las tres áreas de mayor complejidad técnica del GDPR aplicadas a IA — base legal, minimización de datos, y derecho al olvido— tienen implicaciones de diseño que el AI Engineer debe incorporar desde la arquitectura inicial.

La base legal es el fundamento jurídico que justifica cada operación de procesamiento de datos personales. El Art. 6 del GDPR lista las bases legales posibles, y para sistemas de IA las más relevantes son el contrato (el procesamiento es necesario para prestar el servicio al usuario) y el consentimiento (el usuario dio permiso explícito para ese procesamiento específico). La inferencia de un LLM sobre datos del usuario durante una sesión de chat puede justificarse bajo la base legal de contrato si el servicio de IA es lo que el usuario está usando. Pero el fine-tuning del modelo con conversaciones de usuarios —que procesa esos datos para entrenar el modelo, no para prestar el servicio en esa sesión— generalmente requiere consentimiento explícito e informado (Art. 7), que debe ser granular (el usuario puede consentir a que sus conversaciones mejoren el sistema sin consentir a que se usen para entrenar el modelo base), libre (no condicionar el acceso al servicio al consentimiento de fine-tuning), y revocable en cualquier momento.

El principio de minimización de datos (Art. 5.1.c) crea tensión directa con el modelo de logging completo que la sección anterior describió como necesario para seguridad y forense. La minimización exige que los logs no contengan más datos personales de los necesarios para la finalidad declarada; un log de inferencia que almacena el texto completo de cada input del usuario de manera indefinida viola este principio si la finalidad declarada es solo la seguridad

operacional. La solución de diseño correcta es almacenar el texto completo de inputs y outputs cifrado por usuario con un TTL definido y justificado (90 días para investigación de incidentes, por ejemplo), mientras los metadatos de seguridad no-personales (hashes, scores de clasificadores, model_id, latencias) se almacenan con mayor durabilidad. Esta arquitectura satisface simultáneamente los requisitos de seguridad forense y de minimización de datos de GDPR.

El derecho al olvido (Art. 17 GDPR) —la obligación de borrar todos los datos de un usuario cuando lo solicita— es técnicamente el desafío más complejo del GDPR aplicado a sistemas de IA con fine-tuning. Para logs y vectorstores, el borrado es manejable con la arquitectura correcta (cifrado por usuario + descarte de la clave). Para modelos fine-tuned con datos del usuario, el borrado es técnicamente complejo: el modelo "recuerda" los datos en sus pesos, no en una base de datos con índices. Las técnicas de machine unlearning —gradient ascent sobre los datos a olvidar (SISA training), influence function-based unlearning— están en estado activo de investigación y ninguna es perfecta. Para datos de alta sensibilidad, el enfoque más pragmático actualmente es reentrenamiento completo excluyendo los datos del usuario que solicitó el olvido, con documentación explícita de por qué el machine unlearning aproximado no es suficiente para el nivel de riesgo del sistema.

Aspectos técnicos

- **Base legal por operación de procesamiento:** inferencia sobre datos del usuario (base: contrato); almacenamiento de historial para memoria multi-turn (base: contrato o interés legítimo); fine-tuning con conversaciones de usuarios (base: consentimiento explícito, granular, libre y revocable).
- **Minimización en logging de inferencia:** texto completo de input/output cifrado por usuario con TTL de 90 días (justificado por necesidad forense); metadatos de seguridad no-personales (hashes, scores, model_id) con mayor durabilidad; no almacenar más datos personales de los necesarios para la finalidad declarada.
- **Derecho al olvido (Art. 17):** borrado de logs (descarte de clave de cifrado del usuario), historial de conversación, documentos personales en el vectorstore, y datos de fine-tuning; procesable dentro de 30 días con confirmación de borrado; para modelos fine-tuned, reentrenamiento completo excluyendo los datos del usuario como aproximación actual.
- **Machine unlearning:** técnicas como SISA training y gradient ascent sobre los datos a olvidar; ninguna es perfecta; el estado del arte 2024-2025 admite que el reentrenamiento completo sigue siendo el método más confiable para datos de alta sensibilidad.

- **Transferencias internacionales:** datos de usuarios europeos procesados en servidores en us-east-1 requieren Standard Contractual Clauses (SCCs) o certificación bajo EU-US Data Privacy Framework; los proveedores de LLMs (OpenAI, Anthropic, Google) ofrecen estos mecanismos en sus contratos de enterprise.

El GDPR aplicado a sistemas de IA requiere que el equipo de ingeniería tome decisiones de diseño específicas que serían innecesarias sin datos personales: arquitectura de borrado selectivo en logs, gestión granular de consentimiento para fine-tuning, machine unlearning o reentrenamiento para el derecho al olvido, y minimización activa de la retención de PII en todas las capas del sistema.

Módulo 9 – Capítulo 09 – Sección 03

HIPAA y datos de salud en sistemas de IA: requisitos técnicos de salvaguarda

HIPAA (Health Insurance Portability and Accountability Act, 1996) establece requisitos de seguridad y privacidad para Protected Health Information (PHI) que aplican plenamente a cualquier sistema de IA que procese información de salud de pacientes en el contexto del healthcare estadounidense. El alcance de "procesar PHI" es amplio en el contexto de IA: un chatbot que asiste a pacientes con preguntas sobre sus síntomas procesa PHI, un sistema RAG que indexa historiales clínicos para asistir a médicos en diagnósticos procesa PHI, un agente que analiza notas de médicos y sugiere órdenes clínicas procesa PHI, y un sistema de fine-tuning que usa conversaciones de pacientes como datos de entrenamiento procesa PHI. La firma de un Business Associate Agreement (BAA) con el proveedor de cloud o de modelo (OpenAI, Microsoft Azure, Google Cloud) es el mecanismo legal que permite este procesamiento, pero el BAA transfiere la responsabilidad de implementar los controles técnicos específicos al desarrollador de la aplicación.

Los Technical Safeguards del HIPAA Security Rule (45 CFR 164.312) son los requisitos de ingeniería directamente responsabilidad del AI Engineer. La sección 164.312(a)(1) exige Access Controls: identificación única de usuario para cada persona que accede a PHI, procedimientos de emergencia para acceso cuando los sistemas normales fallan, cierre automático de sesión, y cifrado/descifrado. La sección 164.312(b) exige Audit Controls: hardware, software y procedimientos para registrar y examinar accesos a sistemas que contienen PHI —lo que en sistemas de IA significa que el audit log de inferencia descrito en el Capítulo 8 es un requisito legal explícito de HIPAA. La sección 164.312(c)(1) exige Integrity Controls: protección de PHI de alteración o destrucción no autorizada —que en sistemas de IA incluye la inmutabilidad de los logs de inferencia y la protección de los vectorstores que indexan registros clínicos. La sección 164.312(e)(1) exige Transmission Security: cifrado de PHI en tránsito entre todos los componentes del sistema.

El proceso de de-identificación de PHI es el mecanismo que permite usar datos de salud en sistemas de IA sin las restricciones de HIPAA: datos correctamente de-identificados dejan de

ser PHI y pueden usarse para entrenamiento, evaluación y análisis sin los requisitos de HIPAA. El HIPAA Safe Harbor method especifica 18 categorías de identificadores específicos que deben eliminarse (nombre, fechas específicas, direcciones, números de teléfono y fax, emails, SSN, números de historia clínica, números de beneficiario de seguro, números de cuenta, certificados y licencias, VINs, dispositivos y números de serie, URLs, IPs, biometría, fotos de cara completa, y otros números de identificación únicos). Después de eliminar estos 18 identificadores, los datos de salud resultantes no son PHI y pueden usarse sin restricciones de HIPAA. El Expert Determination method es la alternativa: un experto estadístico certifica que el riesgo de re-identificación es muy pequeño con base en el análisis de los datos específicos.

Aspectos técnicos

- **Technical Safeguards de HIPAA (45 CFR 164.312):** Access Controls (identificación única, cierre automático de sesión, cifrado); Audit Controls (registro de accesos a PHI — obligación legal del audit log de inferencia—); Integrity Controls (protección de PHI de alteración no autorizada); Transmission Security (cifrado en tránsito).
- **Cifrado de PHI en sistemas de IA:** TLS 1.2 mínimo (1.3 recomendado) para PHI en tránsito; AES-256 para PHI en reposo en vectorstores, bases de datos de conversación y logs de inferencia; NIST-approved algorithms según guidance del HHS.
- **Audit logs de PHI:** registro de qué PHI fue accedida, por qué usuario, en qué momento, y con qué propósito; mantenidos por mínimo 6 años (HIPAA Retention Rule); suficientes para responder a auditorías del OCR y análisis forense post-breach.
- **De-identificación Safe Harbor:** eliminación de los 18 identificadores específicos de HIPAA; datos de-identificados dejan de ser PHI y pueden usarse para fine-tuning y evaluación sin restricciones de HIPAA; verificar que el proceso de de-identificación sea completo para todos los campos del sistema (incluyendo metadatos de documentos).
- **BAA y responsabilidad de proveedores:** Azure OpenAI, AWS Bedrock (con modelos de Anthropic), y Google Vertex AI ofrecen BAAs; el BAA no transfiere la responsabilidad de implementar los Technical Safeguards al proveedor — el desarrollador sigue siendo responsable de los controles en su código y arquitectura.

Nota del Arquitecto: Un error frecuente en el contexto de HIPAA es asumir que firmar el BAA con el proveedor de cloud o de modelo es suficiente para cumplir. El BAA solo cubre la responsabilidad del proveedor por PHI que pasa a través de sus sistemas; no cubre cómo la aplicación maneja, almacena, o procesa esa PHI. He

auditado sistemas con BAA firmado con Azure OpenAI que almacenaban logs de inferencia con PHI en plaintext en Azure Blob Storage sin cifrado en reposo, o que no tenían implementados los Audit Controls de acceso a esos logs. El BAA es el punto de partida, no el punto final del compliance.

HIPAA aplica al sistema de IA completo —el modelo, el vectorstore, los logs de inferencia, el historial de conversación, y los datos de fine-tuning— no solo a la base de datos de pacientes; la firma de un BAA con los proveedores de cloud o de modelo no libera al desarrollador de implementar los Technical Safeguards en su propio código y arquitectura.

Módulo 9 – Capítulo 09 – Sección 04

NIST AI RMF: el framework de gestión de riesgos de IA como lenguaje común

El NIST AI Risk Management Framework (AI RMF 1.0, publicado en enero de 2023 por el National Institute of Standards and Technology) es el marco de referencia para gestión de riesgos de IA más adoptado en el sector privado y gubernamental estadounidense, y está emergiendo como el complemento natural del EU AI Act para organizaciones que operan en ambos mercados. Mientras el EU AI Act es una regulación de cumplimiento obligatorio con multas para incumplimiento, el NIST AI RMF es un framework voluntario de buenas prácticas —no tiene fuerza de ley— pero su adopción está siendo requerida de facto por organismos reguladores sectoriales (la FDA para dispositivos médicos con IA, la NHTSA para vehículos autónomos), por el gobierno federal americano en sus requisitos de contratación, y por grandes corporaciones en sus cadenas de suministro de tecnología. Un AI Engineer que trabaja en el mercado americano en 2025-2026 encontrará el AI RMF en prácticamente cualquier proceso de procurement o auditoría de seguridad en sectores regulados.

El AI RMF organiza su Core en cuatro funciones interdependientes que articulan un ciclo completo de gestión de riesgo. La función GOVERN establece la cultura, las políticas, los procesos, y los roles organizacionales para la gestión sistemática del riesgo de IA: quién es el AI Risk Owner para cada sistema, cómo se toman y documentan las decisiones de aceptación de riesgo, qué proceso de revisión existe para sistemas de IA de alto riesgo, y cómo se integra la gestión de riesgo de IA en el gobierno corporativo. Para el lector de este libro, GOVERN corresponde a las preguntas de arquitectura del Capítulo 10: ¿quién toma la decisión de desplegar un sistema con cierto perfil de riesgo?, ¿qué proceso de revisión existe antes del deployment?

La función MAP identifica y categoriza los riesgos de IA en el contexto específico del sistema y su uso. Esto es esencialmente el threat modeling del Capítulo 1 y 10: identificar qué actores podrían atacar el sistema, con qué motivaciones y capacidades, qué consecuencias tendría cada tipo de falla (daño físico, daño financiero, discriminación, violación de privacidad), y qué lugar ocupa el sistema en el espectro de riesgo del AI RMF. El AI RMF Playbook (publicado

por NIST junto con el framework) mapea cada subcategoría de MAP a acciones sugeridas específicas, que para sistemas de LLM incluyen explícitamente la evaluación con OWASP LLM Top 10 y MITRE ATLAS.

La función MEASURE define métricas cuantificables para los riesgos identificados en MAP y establece procesos para monitorizarlos en producción. Para sistemas de IA construidos con los controles de este módulo, las métricas naturales de MEASURE incluyen: la tasa de false positives y false negatives del clasificador de input (LlamaGuard) en el dataset de evaluación, el tiempo medio de detección de jailbreaks en producción medido desde el timestamp del evento hasta la alerta en el SIEM, el porcentaje de cobertura del threat model en el último ejercicio de red teaming, y la tasa de degradación de accuracy del modelo ante perturbaciones adversariales estándar. MEASURE es la función que convierte los controles técnicos del módulo en métricas de seguridad reportables a la dirección y a los auditores.

La función MANAGE cierra el ciclo implementando los controles de mitigación para riesgos priorizados, manteniendo un risk register actualizado con el riesgo residual documentado, y estableciendo los procesos de revisión periódica del risk profile del sistema. El risk register es el artefacto central de MANAGE: un documento que lista cada riesgo identificado en MAP, su severidad estimada, el control de mitigación implementado, el riesgo residual después del control, y la decisión de aceptación o rechazo del riesgo residual con la justificación explícita. Los riesgos que se deciden aceptar —porque el costo de mitigación supera el riesgo— deben documentarse explícitamente con quién tomó la decisión y por qué.

Aspectos técnicos

- **Función GOVERN:** políticas internas de gestión de riesgo de IA, roles definidos (AI Risk Owner, Data Steward, Model Validator), comité de revisión de IA para sistemas de alto riesgo, procesos de escalation documentados; correspondencia con los principios de security by design del Capítulo 10.
- **Función MAP:** categorización del sistema por dominio y nivel de autonomía, identificación de consecuencias de fallas (daño físico, financiero, privacidad), mapeo a OWASP LLM Top 10 y MITRE ATLAS; correspondencia con el threat modeling de los Capítulos 1 y 10.
- **Función MEASURE:** métricas cuantificables de los riesgos identificados — tasa de F1 del clasificador de seguridad, tiempo medio de detección de jailbreaks, cobertura del red teaming contra el threat model, degradación ante perturbaciones adversariales; correspondencia con los Capítulos 4, 7 y 8.

- **Función MANAGE:** risk register con riesgo residual documentado, controles de mitigación implementados, decisiones de aceptación de riesgo con justificación explícita, revisión periódica (recomendada trimestralmente por el AI RMF Playbook); correspondencia con los controles técnicos de los Capítulos 5-9.
- **AI RMF + EU AI Act:** el AI RMF proporciona el proceso y el vocabulario; el EU AI Act proporciona los requisitos legales obligatorios; para organizaciones que operan en ambos mercados, el AI RMF implementado correctamente satisface o facilita la satisfacción de muchos requisitos del EU AI Act de alto riesgo.

Nota del Arquitecto: El valor operacional del NIST AI RMF no está en el framework abstracto sino en el AI RMF Playbook, disponible gratuitamente en nist.gov. El Playbook traduce cada subcategoría del framework en acciones sugeridas concretas con orientación sobre cómo implementarlas. Para el AI Engineer que necesita demostrar a la dirección que el sistema de IA tiene gestión de riesgo estructurada, el Playbook proporciona el vocabulario y la estructura de proceso que convierten controles técnicos implementados en evidencia de gestión de riesgo documentada.

El NIST AI RMF proporciona el vocabulario y la estructura de proceso GOVERN-MAP-MEASURE-MANAGE para gestionar el riesgo de IA de forma sistemática, y su adopción en el mercado americano es tan extensa que un equipo que no lo conoce tiene dificultad para participar en conversaciones de procurement y auditoría de seguridad en sectores regulados.

Módulo 9 – Capítulo 09 – Sección 05

Mapeo de controles: cómo los controles técnicos satisfacen los requisitos regulatorios

El mapeo de controles es la actividad que conecta el trabajo de ingeniería de seguridad —los controles técnicos que el equipo implementó— con la demostración de compliance ante reguladores, auditores, clientes enterprise, y la dirección de la organización. Sin este mapeo, los dos mundos permanecen desconectados: el equipo de ingeniería puede tener controles excelentes sin poder articular qué requisito regulatorio satisfacen, o puede conocer los requisitos regulatorios sin saber qué controles técnicos implementar para cumplirlos. La control matrix —la herramienta que formaliza este mapeo— es el artefacto que hace visible la conexión entre ambos mundos y que convierte el trabajo técnico en evidencia auditable de compliance.

La estructura de una control matrix efectiva tiene cuatro componentes para cada entrada. El requisito regulatorio, identificado con precisión: no "GDPR exige privacidad" sino "GDPR Art. 25.1 exige que el responsable del tratamiento aplique medidas técnicas y organizativas apropiadas para que, por defecto, solo se traten los datos personales que sean necesarios para cada finalidad". El control técnico implementado: "pipeline de detección y redacción de PII con Microsoft Presidio ejecutado antes de la indexación en el vectorstore; TTL de 90 días para el texto completo de inputs y outputs de usuarios en los logs de inferencia". La evidencia de implementación: el artefacto que demuestra que el control existe y está activo, no solo documentado —puede ser código en el repositorio, una captura de la configuración del servicio, un resultado de prueba, o una muestra de log. Y el estado: implementado, parcialmente implementado (con descripción de la brecha), o gap (el requisito no está cubierto por ningún control).

Los ejemplos de mapeo concretos ilustran cómo se aplica en práctica. GDPR Art. 25 (Privacy by Design) mapea a: pipeline de de-identificación de PII con Presidio antes de indexar en RAG, differential privacy con DP-SGD y epsilon = 5 durante el fine-tuning, y cifrado por usuario del texto de logs de inferencia con TTL de 90 días. La evidencia es la documentación del pipeline de ingestión RAG, la configuración de Opacus en el pipeline de fine-tuning, y el

schema del sistema de logging con TTL documentado. EU AI Act Art. 9 (Risk Management System) mapea a: threat model documentado con STRIDE aplicado al DFD del sistema, actualizado en cada release significativo, y red teaming trimestral con reporte de hallazgos y mitigaciones verificadas. La evidencia es el documento del threat model en el repositorio y los reportes de red teaming archivados con fecha. HIPAA 45 CFR 164.312(b) (Audit Controls) mapea a: el security event schema del Capítulo 8 con user_id, retrieved_document_ids, y tool_calls, almacenado en S3 Object Lock con retention de 6 años y cadena de firmas criptográficas.

Los gaps de compliance son la parte más valiosa de la control matrix porque hacen visible lo que está incompleto antes de una auditoría. Un gap identificado internamente puede gestionarse proactivamente: asignarse a un owner, priorizarse con base en su nivel de riesgo, y resolverse con un plan de implementación con fecha. Un gap descubierto por un auditor externo es un finding de auditoría que daña la relación con el auditor y puede iniciar un proceso regulatorio. La control matrix que identifica gaps internamente es un mecanismo de mejora continua; la que oculta gaps es un pasivo regulatorio de tiempo limitado.

Aspectos técnicos

- **Estructura de la control matrix:** columnas de regulación (EU AI Act Art. X, GDPR Art. Y, HIPAA 45 CFR Z, NIST AI RMF Función.Categoría), requisito textual resumido, control técnico implementado, evidencia de implementación (código/configuración/resultados de prueba), y estado (implementado/parcial/gap).
- **Ejemplos de mapeo:** GDPR Art. 25 → Presidio en ingestión RAG + DP-SGD + cifrado por usuario en logs; EU AI Act Art. 9 → threat model documentado + red teaming trimestral; HIPAA 164.312(b) → security event schema con audit trail de acceso a PHI almacenado en WORM storage.
- **Gestión de gaps:** gaps documentados en la control matrix con owner asignado, nivel de riesgo, y plan de implementación con fecha; preferibles a gaps ocultos porque pueden gestionarse proactivamente antes de una auditoría.
- **Control matrix como código:** almacenar la control matrix en YAML o JSON en el repositorio del proyecto con versioning en git; permite diff entre versiones para ver la evolución del estado de compliance, y automatización de reporting para la dirección y auditores.
- **Herramientas de automatización parcial:** Drata, Vanta, Secureframe automatizan la recolección de evidencias de controles técnicos verificables automáticamente (cifrado

habilitado en S3, MFA activo, logs fluyendo al SIEM); los controles específicos de IA (resultados de red teaming, configuración de DP) requieren evidencia manual.

Nota del Arquitecto: *La control matrix como documento en YAML en el repositorio de git tiene una ventaja operacional que los Excel compartidos en SharePoint no tienen: cada cambio en el estado de un control genera un commit con autor, fecha, y descripción del cambio. Cuando un auditor pregunta "¿cuándo implementaron el cifrado del vectorstore?", la respuesta está en el git log de la control matrix. Esa trazabilidad del historial de compliance es tan valiosa como el estado actual.*

La control matrix debe ser un documento vivo, mantenido en el repositorio del proyecto como código con versioning explícito, actualizado ante cualquier cambio en los controles técnicos o en los requisitos regulatorios, y revisado como mínimo semestralmente y ante cada actualización de guidance de los organismos reguladores.

Módulo 9 – Capítulo 09 – Sección 06

Cierre: el cumplimiento regulatorio es el piso mínimo de seguridad, no el techo

La distinción entre compliance y seguridad es una de las más importantes que un AI Engineer puede interiorizar. El compliance regulatorio establece el piso mínimo: el conjunto de controles que la ley exige implementar para operar legalmente en una jurisdicción específica. Un sistema que cumple con el EU AI Act, el GDPR, el HIPAA, y el NIST AI RMF ha satisfecho todas las obligaciones legales en sus respectivas jurisdicciones. Y un sistema así puede aun ser comprometido mediante un ataque de RAG poisoning con documentos que contienen instrucciones adversariales, mediante jailbreaking con técnicas de many-shot que el modelo no fue parcheado para resistir, o mediante prompt injection indirecta en emails que el agente procesa —porque ninguna de esas regulaciones especifica defensas contra esos ataques técnicos específicos de manera que los operadores puedan verificar.

Los reguladores legislan sobre amenazas conocidas y sobre principios generales, no sobre el estado del arte de la investigación adversarial. El EU AI Act exige "robustez ante ataques adversariales" sin especificar qué ataques ni qué nivel de robustez; HIPAA exige "audit controls" sin especificar el schema del log de inferencia ni los scores de clasificadores de seguridad. Esta abstracción es intencional —las regulaciones deben sobrevivir la evolución tecnológica— pero deja una brecha que el equipo de ingeniería debe llenar con decisiones técnicas informadas por el estado del arte de la seguridad de IA, no solo por la letra de la regulación.

El posture de seguridad correcto invierte el orden de las prioridades: construir primero el sistema más seguro posible basado en el threat model real del sistema específico —aplicando los controles técnicos de los Capítulos 1-8 de este módulo— y luego verificar que ese sistema también satisface los requisitos regulatorios aplicables mediante la control matrix del Capítulo 9. Cuando el sistema está correctamente diseñado para resistir los ataques reales que el threat model identifica, el compliance suele ser una consecuencia natural, porque las regulaciones se escribieron precisamente para requerir controles que protejan ante esos ataques. El equipo que invierte el orden —busca primero qué exige el regulador e implementa

solo eso— termina con un sistema que puede aprobar una auditoría de compliance pero que tiene brechas de seguridad reales ante amenazas que el regulador no anticipó.

Conceptos clave del capítulo

- **EU AI Act:** clasificación por riesgo (inaceptable/alto/limitado/mínimo) aplicada a la aplicación completa, no solo al modelo base; requisitos técnicos de sistemas de alto riesgo incluyen Risk Management System, Data Governance, robustez ante adversarial attacks (Art. 15), y human oversight obligatorio.
- **GDPR en sistemas de IA:** base legal por cada finalidad de procesamiento, minimización activa de datos en logs, machine unlearning (o reentrenamiento) para el derecho al olvido, BAAs con proveedores cloud para PHI, y Standard Contractual Clauses para transferencias internacionales.
- **HIPAA en sistemas de IA:** Technical Safeguards (45 CFR 164.312) para acceso, auditoría, integridad y transmisión de PHI; de-identificación Safe Harbor o Expert Determination; logs de acceso a PHI mantenidos 6 años; BAA con todos los proveedores que acceden a PHI.
- **NIST AI RMF:** framework voluntario GOVERN-MAP-MEASURE-MANAGE; vocabulario y estructura de proceso para gestión sistemática de riesgos de IA; adoptado de facto como requisito en sectores regulados americanos y complemento al EU AI Act para organizaciones en ambos mercados.
- **Control matrix:** mapeo explícito de requisito regulatorio → control técnico → evidencia de implementación; documento vivo en YAML versionado en git; identifica gaps proactivamente antes de auditorías externas.

"Compliance is not security. Meeting a checklist tells you where you were last year — not where the attackers are today." — Mikko Hyppönen, Chief Research Officer de WithSecure y uno de los investigadores de ciberseguridad más reconocidos mundialmente, sobre la diferencia fundamental entre compliance y seguridad operacional real: el compliance es condición necesaria pero no suficiente para operar sistemas de IA seguros en producción.